PORTFOLIO / MCP SECURITY

Secure MCP Integration Gateway

AI darf eine Capability wählen. Business-Autorität darf sie nicht selbst erzeugen.

77 **verifizierte Checks**

26 Java + 40 live HTTP/MCP + 11 release checks

Java 21 · MCP 2026-07-28 focused subset

Release candidate 1.0.0-rc.1

DAS RISIKO

“Just expose the API as a tool”

is not a security model.

Wer wählt den Tenant?

Kann das Modell URL oder SQL injizieren?

Kann ein Token für API A API B erreichen?

Darf eine alte Approval geänderte Argumente autorisieren?

Was passiert beim Retry eines Writes?

ARCHITEKTUR

Trust Boundaries trennen.

- identitätsbasierter Tenant
- Scope + Schema Policy
- exakte Human Approval
- Quota + Audit
- eigenes Upstream Credential

KLEINE TOOL-FLÄCHE

4 tools. Not 40.

orders.lookup	READ
inventory.check	READ
customer.documents.list	READ
orders.cancel	APPROVAL + WRITE

Kein beliebiges SQL · keine dynamische URL · kein Tenant-Argument · kein Credential-Argument

EXAKTES APPROVAL BINDING

Approval ≠ generic permission

BOUND	Tenant
BOUND	Requester
BOUND	Tool + unveränderliche Revision
BOUND	kanonischer Argument-Fingerprint
BOUND	Ablauf + unabhängiger Reviewer

Ein Zeichen ändern → approval_binding_mismatch

ANGRIFFSTESTS

Denials sind Teil des Produkts.

PASS	falsche Token-Audience
PASS	Cross-Tenant Reads
PASS	Self / Cross-Tenant Approval
PASS	URL + SQL Injection
PASS	MCP Header/Body Mismatch
PASS	Duplicate Write Retry
PASS	Quota-Missbrauch
PASS	Raw-Data Audit Leakage

EVIDENCE

77 deterministic checks

26	40	11
Java	HTTP/MCP	Release

Native Browser und offizieller MCP-v2-SDK-Test bleiben separate explizite Gates - nicht künstlich in die Pass-Zahl eingerechnet.

DAS PRINZIP

AI darf vorschlagen.
Policy entscheidet Autorität.

Identität · Tenant · Ziel · Approval · Idempotency · Audit bleiben deterministisch.

GitHub

github.com/AhadPorkar/secure-mcp-integration-gateway

Java 21 · MCP 2026-07-28 subset · Connector Hub sidecar

Release candidate 1.0.0-rc.1